Task 4

Mentor Review Packet

Public Endpoint Shielding, PII Masking & Automated DAST

Prepared for Datheon internship mentors and project reviewers

05 November 2026

Review scope and safety notice

This is a loopback-only public-lookup training app using fictional certificate records. It is not an identity-verification service and contains no real personal information.

Contents

1 Reviewer at a glance 1
2 Scope and privacy objective 1
3 Shielding workflow 2
4 Representative API and header outputs 2
5 Visual evidence for reviewers 2
6 Automated assurance and limitations 3
7 Mentor review conclusion 4

1 Reviewer at a glance

Task 4 implements a privacy-conscious public credential lookup. The public API returns only the fields needed for verification, dynamically masks email and phone values, applies the same masking to lookup and verification routes, returns generic errors, and adds strict HTTP security headers. The project also includes OpenAPI/Spectral validation, a redacted Gitleaks scan, tests, and a GitHub Actions workflow for automated security checks.

Verified implementation The local suite passed **18 tests** and the TypeScript check passed. Browser JavaScript syntax and Spectral checks also passed. The app returns masked contacts such as `a***n@example.test` and `*******0142`, never the raw fixture values.

What reviewers can verify The embedded browser capture shows the public verification UI explaining "Privacy by design." The API contract and tests verify data minimization, masking, generic `404`/`400` responses, CSP/HSTS/nosniff/clickjacking protections, and no caching or CORS exposure.

2 Scope and privacy objective

Control	Implementation evidence
Public lookup	`GET /api/public/lookup/:referenceId` returns minimal masked data
Verification route	`GET /api/public/verify/:referenceId` uses the same masking builder
Data minimization	No raw email, phone, full name, owner, or unrelated private fields in public payloads
Error handling	Generic `404` for unknown references and `400` for malformed references
Transport headers	CSP, HSTS, `nosniff`, `X-Frame-Options: DENY`, `no-store`, referrer and permissions policies
Automation	Vitest, TypeScript, Spectral, Gitleaks workflow, OWASP ZAP workflow

Raw contact values in public endpoints enable unwanted contact, profiling, correlation with other datasets, and social engineering. Masking reduces direct exposure but is not anonymization; it must be combined with data minimization, abuse controls, and privacy review.

3 Shielding workflow

1. Validate

Accept only a well-formed public reference.

→

2. Minimize

Build a response with verification fields only.

→

3. Mask

Apply dynamic email and phone masking.

→

4. Shield

Add headers and enforce safe browser rendering.

4 Representative API and header outputs

```
GET /api/public/lookup/CERT-1042
HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8
Cache-Control: no-store

{"referenceId":"CERT-1042","status":"Valid","credentialType":"Certificate",
 "issuedYear":2026,"contact":{"email":"a***n@example.test",
 "phone":"*******0142"}}

GET /api/public/lookup/CERT-9999
HTTP/1.1 404 Not Found
{"error":"Not found"}
```

Expected response headers include:

```
Content-Security-Policy: default-src 'self'; ...
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: no-referrer
Cache-Control: no-store
```

The API does not enable permissive CORS and disables the unnecessary `X-Powered-By` server-identifying header. HSTS is configured for deployment correctness but has meaningful transport effect only when the origin is served over HTTPS.

5 Visual evidence for reviewers

The browser capture below shows the public verification page. It communicates the privacy boundary before a reference is entered: names and full contact details are not shown, and the service is labeled as a local fictional training demonstration.

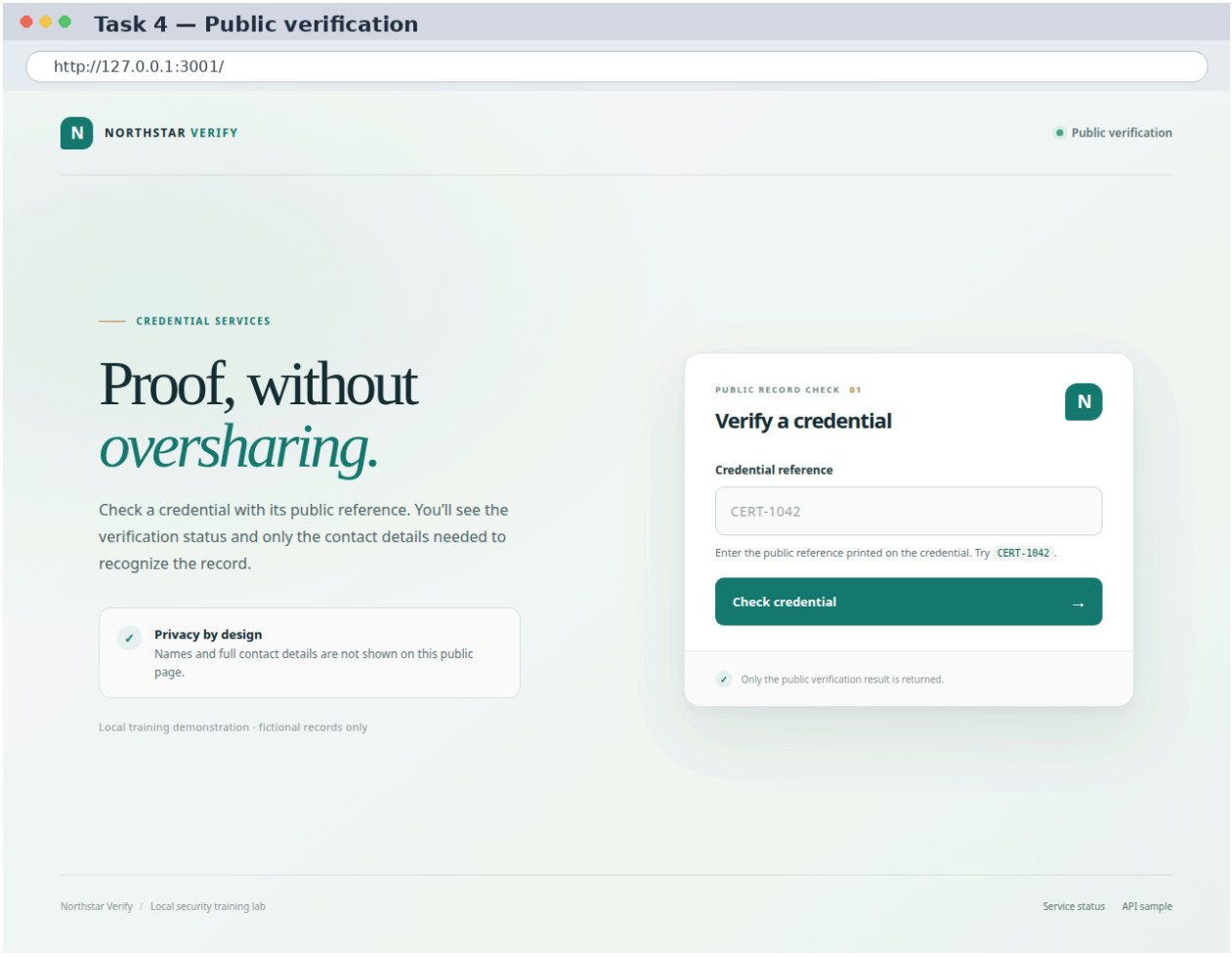


图 1 Browser view of the public verification page at `127.0.0.1:3001/`.

Visual evidence interpretation A reviewer can enter the synthetic reference `CERT-1042` in the local UI and observe only masked contact values. The API tests additionally verify that `CERT-9999` returns a generic not-found response and that neither public route exposes the full fixture email or phone number.

6 Automated assurance and limitations

Check	Result	Reviewer note
Vitest/Supertest API and header suite	18 passed	Masking, privacy, errors, UI assets, headers
TypeScript check	Passed	Strict compile-time verification
Spectral OpenAPI lint	Passed	Contract and masked examples
Gitleaks	No leaks locally	Redacted repository-secret scan

OWASP ZAP	Workflow configured	Docker unavailable in this sandbox; run in GitHub Actions for final artifact

The GitHub Actions workflow is configured for pushes, pull requests, and manual dispatch. It installs pinned dependencies, runs tests and linting, starts the loopback service, runs the OpenAPI ZAP scan, and uploads reports when available. A green GitHub Actions run and ZAP artifact remain the final external-review evidence after the project is placed in the internship repository.

7 Mentor review conclusion

Task 4 demonstrates that public verification can be useful without becoming a raw PII disclosure endpoint. The implementation combines response minimization, dynamic masking, strict browser headers, safe DOM rendering, contract checks, and automated security scanning. The remaining evidence step is execution of the configured CI workflow in the target repository; the local application and its automated tests are already verified.

Documentation note: This packet was assembled with AI assistance from the supplied Task 4 source files. All certificate records and contact values are fictional training fixtures.